

Halal Traceability System - Production Readiness & Security Audit

Assessment date: March 9, 2026

Assessor: Codex (local CLI audit)

Scope: `backend/halal_traceability_api` and `frontend/halal_traceability_app`

Executive Summary

Release recommendation: **DO NOT PUBLISH YET**.

The system boots and most business flows work, but critical authorization issues and security/release blockers remain.

- Broken role-based access control on admin and logistics endpoints
- Password reset flow failing in runtime
- Test suites not passing
- Production hardening not yet applied
- Dependency vulnerabilities reported by Composer audit

Validation Performed

Backend

- `php -v`, `composer --version`, `php artisan about`
- `php artisan route:list`, `php artisan route:list -v`
- `php artisan migrate:status`, `php artisan test`
- API smoke tests via local `php artisan serve` and HTTP calls
- `composer audit --locked`

Frontend

- `flutter --version`, `flutter doctor -v`
- `flutter analyze`, `flutter test`
- `flutter build apk --debug`

Functional Results

Backend

- App boot: **PASS**

- Routes resolve: **PASS**
- Migration status: **PARTIAL** (password reset migration pending)
- PHPUnit: **FAIL** (feature test expects GET / 200 but app returns 405)
- Core API flows (register/login/user/batch/public/logistics/retailer): **PASS**
- /api/forgot-password : **FAIL** (500)
- /api/reports/manifest : **PARTIAL** (placeholder only)

Frontend

- flutter analyze : 17 info/lint issues
- flutter test : **FAIL** (default counter template test mismatch)
- flutter build apk --debug : **PASS**

Security Findings (Prioritized)

Critical

1. Admin endpoints accessible to non-admin users. Verified with processor token receiving HTTP 200 from /api/admin/stats .
2. Logistics endpoints accessible to non-logistics users. Verified with processor token successfully calling /api/logistics/incident and /api/logistics/checkpoint .

High

1. Production hardening not enabled: APP_ENV=local , APP_DEBUG=true , LOG_LEVEL=debug .
2. Missing security headers: CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.
3. No effective backend login throttling observed during repeated invalid login attempts.

Medium

1. Password reset flow broken due to missing password_reset_tokens table (runtime 500).
2. Approval workflow inconsistency: registration auto-approves users while login includes pending-approval logic.
3. Sanctum token expiration is unlimited (expiration => null).
4. Composer advisories detected (1 high + 3 medium): phpunit/phpunit , league/commonmark , psy/psysh , symfony/process .
5. Profile update field mismatch (phone vs phone_number).

Low

1. Frontend API base URL is hardcoded for emulator host and must be environment-driven for production.

Release Decision

NO-GO for production deployment until blockers are fixed.

Minimum blockers before publish:

1. Enforce role-based authorization for admin/logistics/retailer endpoints.
2. Run pending password reset migration and validate forgot-password flow.
3. Apply production environment hardening and disable debug mode.
4. Add auth endpoint throttling/rate limits.
5. Patch dependency vulnerabilities and re-run audit.
6. Make backend and frontend tests pass in CI.

Conclusion

Functionality is close, but confirmed authorization bypasses and incomplete hardening make production release unsafe at this stage.